

## CWE-707: Improper Neutralization

Weakness ID: 707

Vulnerability Mapping: **DISCOURAGED**

Abstraction: Pillar

View customized information:

Conceptual

Operational

Mapping  
Friendly**Complete**

Custom

### Description

The product does not ensure or incorrectly ensures that structured messages or data are well-formed and that certain security properties are met before being read from an upstream component or sent to a downstream component.

### Extended Description

If a message is malformed, it may cause the message to be incorrectly interpreted.

Neutralization is an abstract term for any technique that ensures that input (and output) conforms with expectations and is "safe." This can be done by:

- checking that the input/output is already "safe" (e.g. validation)
- transformation of the input/output to be "safe" using techniques such as filtering, encoding/decoding, escaping/unescaping, quoting/unquoting, or canonicalization
- preventing the input/output from being directly provided by an attacker (e.g. "indirect selection" that maps externally-provided values to internally-controlled values)
- preventing the input/output from being processed at all

This weakness typically applies in cases where the product prepares a control message that another process must act on, such as a command or query, and malicious input that was intended as data, can enter the control plane instead. However, this weakness also applies to more general cases where there are not always control implications.

### Common Consequences



#### Impact

#### Details

*Other*

Scope: Other

### Relationships



#### Relevant to the view "Research Concepts" (View-1000)

| Nature   | Type | ID                   | Name                                                                                               |
|----------|------|----------------------|----------------------------------------------------------------------------------------------------|
| MemberOf |      | <a href="#">1000</a> | Research Concepts                                                                                  |
| ParentOf |      | <a href="#">20</a>   | Improper Input Validation                                                                          |
| ParentOf |      | <a href="#">74</a>   | Improper Neutralization of Special Elements in Output Used by a Downstream Component ('Injection') |
| ParentOf |      | <a href="#">116</a>  | Improper Encoding or Escaping of Output                                                            |
| ParentOf |      | <a href="#">138</a>  | Improper Neutralization of Special Elements                                                        |
| ParentOf |      | <a href="#">170</a>  | Improper Null Termination                                                                          |
| ParentOf |      | <a href="#">172</a>  | Encoding Error                                                                                     |
| ParentOf |      | <a href="#">182</a>  | Collapse of Data into Unsafe Value                                                                 |
| ParentOf |      | <a href="#">228</a>  | Improper Handling of Syntactically Invalid Structure                                               |
| ParentOf |      | <a href="#">240</a>  | Improper Handling of Inconsistent Structural Elements                                              |
| ParentOf |      | <a href="#">463</a>  | Deletion of Data Structure Sentinel                                                                |
| ParentOf |      | <a href="#">1426</a> | Improper Validation of Generative AI Output                                                        |

#### Relevant to the view "Architectural Concepts" (View-1008)

| Nature   | Type | ID                   | Name                     |
|----------|------|----------------------|--------------------------|
| MemberOf |      | <a href="#">1020</a> | Verify Message Integrity |

▼ Modes Of Introduction

|  |                                                                                                 |
|--------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| Phase                                                                          | Note                                                                                            |
| Implementation                                                                 | REALIZATION: This weakness is caused during implementation of an architectural security tactic. |

▼ Applicable Platforms

|  |                                                                     |
|----------------------------------------------------------------------------------|---------------------------------------------------------------------|
| Languages                                                                        | Class: Not Language-Specific ( <i>Undetermined Prevalence</i> )     |
| Operating Systems                                                                | Class: Not OS-Specific ( <i>Undetermined Prevalence</i> )           |
| Architectures                                                                    | Class: Not Architecture-Specific ( <i>Undetermined Prevalence</i> ) |
| Technologies                                                                     | Class: Not Technology-Specific ( <i>Undetermined Prevalence</i> )   |

▼ Weakness Ordinalities

| Ordinality | Description                                                 |
|------------|-------------------------------------------------------------|
| Primary    | (where the weakness exists independent of other weaknesses) |

▼ Detection Methods

| Method                    | Details                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Automated Static Analysis | Automated static analysis, commonly referred to as Static Application Security Testing (SAST), can find some instances of this weakness by analyzing source code (or binary/compiled code) without having to execute it. Typically, this is done by building a model of data flow and control flow, then searching for potentially-vulnerable patterns that connect "sources" (origins of input) with "sinks" (destinations where the data interacts with external components, a lower layer such as the OS, etc.) |

▼ Memberships

|  |                                                                                     |                      |                                                       |
|------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------|----------------------|-------------------------------------------------------|
| Nature                                                                             | Type                                                                                | ID                   | Name                                                  |
| MemberOf                                                                           |  | <a href="#">990</a>  | SFP Secondary Cluster: Tainted Input to Command       |
| MemberOf                                                                           |  | <a href="#">1370</a> | ICS Supply Chain: Common Mode Frailties               |
| MemberOf                                                                           |  | <a href="#">1407</a> | Comprehensive Categorization: Improper Neutralization |

▼ Vulnerability Mapping Notes

| Usage     | <b>DISCOURAGED</b> ( <i>this CWE ID should not be used to map to real-world vulnerabilities</i> ) |
|-----------|---------------------------------------------------------------------------------------------------|
| Reason    | Abstraction                                                                                       |
| Rationale | This CWE entry is extremely high-level, a Pillar.                                                 |
| Comments  | Consider children or descendants of this entry instead.                                           |

▼ Notes

**Maintenance**

Concepts such as validation, data transformation, and neutralization are being refined, so relationships between [CWE-20](#) and other entries such as [CWE-707](#) may change in future versions, along with an update to the Vulnerability Theory document.

▼ Related Attack Patterns

| CAPEC-ID                  | Attack Pattern Name                    |
|---------------------------|----------------------------------------|
| <a href="#">CAPEC-250</a> | XML Injection                          |
| <a href="#">CAPEC-276</a> | Inter-component Protocol Manipulation  |
| <a href="#">CAPEC-277</a> | Data Interchange Protocol Manipulation |
| <a href="#">CAPEC-278</a> | Web Services Protocol Manipulation     |

|                           |                                                                    |
|---------------------------|--------------------------------------------------------------------|
| <a href="#">CAPEC-279</a> | SOAP Manipulation                                                  |
| <a href="#">CAPEC-3</a>   | Using Leading 'Ghost' Character Sequences to Bypass Input Filters  |
| <a href="#">CAPEC-43</a>  | Exploiting Multiple Input Interpretation Layers                    |
| <a href="#">CAPEC-468</a> | Generic Cross-Browser Cross-Domain Theft                           |
| <a href="#">CAPEC-52</a>  | Embedding NULL Bytes                                               |
| <a href="#">CAPEC-53</a>  | Postfix, Null Terminate, and Backslash                             |
| <a href="#">CAPEC-64</a>  | Using Slashes and URL Encoding Combined to Bypass Validation Logic |
| <a href="#">CAPEC-7</a>   | Blind SQL Injection                                                |
| <a href="#">CAPEC-78</a>  | Using Escaped Slashes in Alternate Encoding                        |
| <a href="#">CAPEC-79</a>  | Using Slashes in Alternate Encoding                                |
| <a href="#">CAPEC-83</a>  | XPath Injection                                                    |
| <a href="#">CAPEC-84</a>  | XQuery Injection                                                   |

## ▼ Content History

| ▼ Submissions                                                                                                                                                                        |                  |              |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------|--------------|
| Submission Date                                                                                                                                                                      | Submitter        | Organization |
| 2008-09-09<br>(CWE 1.0, 2008-09-09)                                                                                                                                                  | CWE Content Team | MITRE        |
| <i>Note: this date reflects when the entry was first published. Draft versions of this entry were provided to members of the CWE community and modified between Draft 9 and 1.0.</i> |                  |              |
| ► Modifications                                                                                                                                                                      |                  |              |
| ► Previous Entry Names                                                                                                                                                               |                  |              |